MediCore · Matriz de riesgos (confidencialidad, integridad y disponibilidad)

Escala: probabilidad e impacto de 1 (bajo) a 3 (alto). Nivel = probabilidad × impacto: 1–2 bajo, 3–4 medio, 6–9 alto. "Residual" es el nivel después de los controles que ya existen.

ID	Dim.	Riesgo	Prob.	Imp.	Nivel	Control implementado	Evidencia	Residual
R-01	C	Un usuario lee datos clínicos de otro paciente (IDOR)	2	3	6	Autorización por recurso; acceso ajeno responde 404 y se audita	`ClinicalApiTests`, `LaboratoryApiTests`, Insomnia	Bajo
R-02	C	Un rol administrativo accede a información clínica	2	3	6	RBAC: Recepción y Administrador sin acceso clínico	`IdentityApiTests`, Insomnia, Cypress `acceso-permisos`	Bajo
R-03	C	Datos clínicos en bitácoras, auditoría o eventos	2	3	6	Auditoría solo con identificadores; eventos sin contenido	Pruebas de bitácoras, `PatientEventsTests`	Bajo
R-04	C	Sesión robada o token reutilizado	2	3	6	JWT de 15 min, refresco de un solo uso, sesión en Redis, cookie HttpOnly	`IdentityApiTests`	Bajo
R-05	C	Secretos en el repositorio	2	3	6	`.env` ignorados, plantillas de ejemplo, Ansible Vault	Revisión de archivos versionados	Bajo
R-06	C	Vulnerabilidad web explotable en QA	2	3	6	CSP, cabeceras, antiforgery, validación de entrada	OWASP ZAP web y API	Bajo
R-07	C/I	Dependencia con vulnerabilidad conocida	2	3	6	Análisis en el pipeline	Dependency-Check, npm audit, NuGet	Medio: revisar avisos de Redis
R-08	I	Doble reserva de un horario bajo alta demanda	3	3	9	Exclusión en PostgreSQL, candados de asesoría, reintento	`AppointmentsApiTests`, k6, consulta de solapes	Bajo
R-09	I	Reserva duplicada por reintento del cliente	3	2	6	`Idempotency-Key` y detección de la misma reserva	`AppointmentsApiTests`, Insomnia, Maestro	Bajo
R-10	I	Alteración de registros clínicos	1	3	3	Sin edición ni borrado: PUT, PATCH y DELETE responden 405	`ClinicalApiTests`, Insomnia	Bajo

ID	Dim.	Riesgo	Prob.	Imp.	Nivel	Control implementado	Evidencia	Residual
R-11	I	Datos vencidos en cache llevan a reservar lo ocupado	2	2	4	TTL e invalidación; la base de datos decide la reserva	`AvailabilityApiTests`	Bajo
R-12	I/D	RabbitMQ cae después de registrar un resultado	2	3	6	Outbox transaccional con reintentos	`MessagingTests`, `PatientEventsTests`, `evidencias/resiliencia-qa.md`	Bajo
R-13	I	Mensaje repetido o dañado en la cola	2	2	4	Consumidor idempotente, reintentos y DLQ	`MessagingTests`	Bajo
R-14	D	Redis no disponible	2	3	6	Cache falla abierto; sesiones fallan cerrado por seguridad	`AvailabilityApiTests`, `IdentityApiTests`	Medio: sin Redis no hay sesión
R-15	D	Saturación por picos de demanda	2	3	6	Pruebas de carga con umbrales y lote de outbox	Reportes de k6	Bajo en local; sin medir en Azure
R-16	D	Pérdida de datos por falta de respaldo	2	3	6	Copias cifradas cada 6 h, verificadas; restauración probada (`evidencias/respaldos.md`)	H8-08 cerrado	Medio: siguen en el mismo disco salvo exportación
R-17	D	Servidor único en QA	2	2	4	Reconstrucción por Terraform y Ansible	`evidencias/iac-sin-costo.md`, sin Azure	Medio: abierto
R-18	D	Ambiente de nube no aprovisionado	3	2	6	Código ejecutado sin costo; el equipo decidió no pagar Azure	`evidencias/iac-sin-costo.md`	Alto: abierto
R-19	C/I	App móvil probada solo en emulador	2	2	4	Maestro 8/8 con el código final, contra QA	`evidencias/maestro-codigo-final.md`	Bajo: falta dispositivo físico